

شريك العمر
SHARIK ALOMR

تقرير جاهزية

مراجعة ما قبل الإطلاق · نسخة الويب

الويب جاهز للإطلاق؟ تقرير الفجوات وخطة الاستكمال

مراجعة فنية شاملة للواجهة والـ BFF وقاعدة البيانات والتشغيل — عشان نعرف بالظبط إيه اللي خلص، وإيه اللي ناقص، وإيه اللي لازم يتقفل قبل النشر.

Next.js + React · Express + Prisma · PostgreSQL · Security · Payments · Operations

التاريخ
9 نوفمبر 2026

إعداد المراجعة
محمد مضيان

نطاق المراجعة
الويب + BFF

خاص بالعميل
يُرجى عدم التوزيع

تقرير جاهزية الويب للإنتاج

محتوى التقرير

3	ملخص تنفيذي	01
4	نطاق المراجعة ومنهجيتها	02
5	صورة الجاهزية الحالية	03
6	إنجاز الباك اند – ما تم تنفيذه	04
8	فجوات P0 – أمان وصحة	05
9	فجوات P1 – استكمال المنتج	06
10	فجوات P2 – التشغيل والبنية	07
11	تفصيل أقسام الداشبورد	08
12	خطة التنفيذ المقترحة	09
13	معايير القبول قبل الإطلاق	10
14	مخاطر الإطلاق بالوضع الحالي	11
15	قرارات مطلوبة من العميل	12
16	الخلاصة والخطوة الجاية	13

المراجعة في أرقام

الأساس سليم والمنتج لسه محتاج شغل

الصفحات العامة والمصادقة شغالين على بيانات حقيقية، لكن لوحة التحكم والدفع والتشغيل الإنتاجي لسه ناقصين.

3
مستويات أولوية واضحة

8
بنود حاجزة قبل الإطلاق

12
قسم داشبورد محتاج ربط

0
اختبارات آلية للويب حاليًا

ملاحظة عن التقرير: دي مراجعة فنية للكود والحالة الحالية، مش عرض تصميم. كل بند مكتوب «ناقص» معناه مفيش له تنفيذ فعلي في المشروع دلوقتي – مش مجرد تحسين مقترح.

الخلاصة أولًا

01

ملخص تنفيذي

الويب دلوقتي أقوى من مجرد واجهة تعريفية: الصفحات العامة، الباقات، المقالات، وتسجيل الدخول بكل طرقه شغالين على بيانات حقيقية. لكن لوحة التحكم ولوحة الإدارة لسه واجهات تجريبية، والدفع والتشغيل الإنتاجي لسه مش موجودين. يعني **الأساس سليم، لكن المنتج نفسه محتاج استكمال**.

0	12	8	3
اختبارات آلية أو CI/CD	قسم داشبورد ببيانات تجريبية	بنود P0 حاجزة للإطلاق	مراحل تنفيذ مقترحة

غير الجاهز

- لوحة التحكم كلها ببيانات محلية ومفيش APIs حقيقية وراها.
- لوحة الإدارة مكشوفة لأي زائر وبدون تسجيل دخول أو صلاحيات.
- استعادة كلمة المرور وتغيير رقم الهاتف غير موجودين.
- الاشتراكات والدفع والفواتير والاسترداد غير موجودين.
- مفيش اختبارات آلية ولا مراقبة ولا نسخ احتياطي موثّق.

الجاهز فعلاً

- ✓ الصفحة الرئيسية والباقات والمقالات وتفاصيل المقال.
- ✓ تسجيل حساب جديد ودخول بكلمة مرور أو OTP أو Google.
- ✓ جلسات ويب آمنة، خروج، وإلغاء كل الجلسات.
- ✓ الثيمات الفاتح والغامق، العربي والإنجليزي، والريسبونسيف.
- ✓ BFF مستقل ونفس قاعدة بيانات الموبايل بدون تعديل كود الموبايل.

التوصية المباشرة

ما يتمش الإطلاق العام بالنسخة الحالية. لازم تتقفل بنود P0 الأول – على الأقل حماية المسارات، مصادقة الأدمن، وحفظ الـ onboarding – لأنها مخاطر أمنية وتجربة مستخدم حقيقية، مش تحسينات شكلية.

إيه اللي اتفحص بالظبط

نطاق المراجعة ومنهجيتها

المراجعة غطّت كل ما يخص الويب: واجهة Next.js، وطبقة BFF، وجلسات الويب، وقاعدة البيانات المشتركة، وملفات التشغيل. تطبيق الموبايل خارج النطاق.

طريقة المراجعة

- مراجعة كود الواجهة والـ BFF مسار بمسار.
- حصر كل الشاشات وحالة البيانات وراها.
- تشغيل فحوصات البناء والأنواع والصحة.
- اختبار يدوي لمسارات الدخول والجلسات.

خارج النطاق

- كود تطبيق الموبايل.
- إعادة تصميم الواجهة من الصفر.
- مزايا جديدة مش موجودة في الخطة الحالية.
- تجهيز السيرفرات والاستضافة فعليًا.

داخل النطاق

- الصفحات العامة والمحتوى.
- تسجيل الدخول والتسجيل والجلسات.
- لوحة المستخدم ولوحة الإدارة.
- مسارات الـ BFF والتحقق من المدخلات.
- جداول الويب في قاعدة البيانات.
- إعدادات البيئة والبناء والنشر.

مفيش اختبارات آلية تغطي المراجعة

المشروع الحالي مفيهوش اختبارات unit أو integration أو E2E، ولا pipeline للـ CI. عشان كده التحقق من السلوك اتعمل يدويًا على المسارات الأساسية، وده في حد ذاته بند لازم يتعالج قبل الإنتاج.

إزاي بنصنّف الأولويات؟

الأولوية	المعنى	القرار
P0	أمان أو صحة بيانات أو تجربة مستخدم أساسية.	**لازم تتقفل قبل أي إطلاق عام.**
P1	استكمال المنتج نفسه وربط الأقسام بالبيانات الحقيقية.	**لازم قبل الإطلاق التجاري الكامل.**
P2	تشغيل، جودة، نمو، والتزامات قانونية.	**مهمة جدًا، وممكن تتنفذ بالتوازي أو قبل النمو.**

نظرة سريعة على الحالة

صورة الجاهزية الحالية

الجدول ده بيجاوب على سؤال واحد: لو هنطلق بكرة، كل جزء في الويب هيقف فين؟ الحالة «جاهز» معناها شغال على بيانات حقيقية ومتحقق منه، و«واجهة فقط» معناها الشكل موجود لكن مفيش وظيفة حقيقية وراه.

المنطقة	الحالة	التفاصيل
الصفحات العامة والمحتوى	جاهز	الرئيسية، الباقات، المقالات، وتفاصيل المقال — بيانات حقيقية من الـ BFF.
تسجيل الدخول والتسجيل	جاهز	كلمة مرور، OTP، Google، جلسات، خروج، وترحيب برصيد.
استعادة كلمة المرور	ناقص	مفيش مسار ولا شاشة لاستعادة الحساب.
تغيير أو إضافة رقم الهاتف	ناقص	مستخدم Google بيفضل برقم وهمي ومش قادر يضيف رقم حقيقي.
حماية مسارات الداشبورد	ناقص	الصفحات بتفتح من غير تسجيل دخول — مفيش guard على السيرفر.
لوحة المستخدم	واجهة فقط	12 قسم ببيانات محلية ورسالة «نسخة تجريبية».
لوحة الإدارة	غير جاهزة	مكشوفة للعامة، بيانات وهمية، ومفيش تنفيذ فعلي للأدوار والصلاحيات.
الاشتراكات والدفع	غير موجود	زرار الباقة بيودّي للـ onboarding، مفيش checkout ولا webhooks.
التشغيل والجودة	ناقص	مفيش اختبارات، CI/CD، مراقبة، أو نسخ احتياطي موثّق.
SEO والمحتوى القانوني	جزئي	metadata أساسية و robots فقط — مفيش sitemap ولا صفحات شروط وخصوصية.

اللي شكله شغال لكنه تجريبي

- الترشيحات والبحث والاهتمامات.
- الرسائل والإشعارات والمكالمات.
- المحفظة والولي والمجتمع.
- الملف الشخصي والخصوصية والإعدادات.
- كل شاشات لوحة الإدارة.

اللي بيشتغل على بيانات حقيقية

- ✓ الباقات ومزاياها من قاعدة البيانات.
- ✓ المقالات المنشورة وتفاصيلها.
- ✓ إنشاء الحساب وتأكيد الهاتف.
- ✓ الدخول بكلمة المرور و OTP و Google.
- ✓ الجلسة والخروج وإلغاء كل الجلسات.

إنجاز موثّق

الباك اند اللي تم تنفيذه فعلاً

القسم ده مش خطة ولا وعود. دي قائمة بالجزء اللي اتبنى واتختبر في BFF الويب — كل بند موجود في الكود وله مسار أو جدول أو دليل تشغيل.

9 نوفمبر 2026

تنفيذ وتطوير: محمد مضيان

تأسيس الباك اند والـ BFF، المصادقة والجلسات، وتكامل الواجهة.

إنجاز

#	البند المنفّذ	التفاصيل	الحالة
1	تأسيس BFF مستقل	خدمة Express + TypeScript على بورت 4001، منفصلة عن الموبايل، مع proxy من Next.js.	تم التنفيذ
2	جداول الويب	جدولان منفصلان لجلسات الويب وأكواد OTP، مع فهارس للبحث.	تم التنفيذ
3	الجلسات	كوكي httpOnly، تخزين HMAC-SHA256، مدة صلاحية، تحقق، خروج، وإلغاء كل الجلسات.	تم التنفيذ
4	التسجيل	تسجيل بالهاتف مع OTP من 5 أرقام وكلمة مرور اختيارية.	تم التنفيذ
5	الدخول بكلمة المرور	دخول بهاتف أو بريد مع bcrypt وتسجيل محاولات الدخول.	تم التنفيذ
6	الدخول بـ OTP	إرسال والتحقق من OTP مع صلاحية ومحاولات وإعادة إرسال.	تم التنفيذ
7	الدخول بـ Google	تحقق من توكن Google وربط الحساب ورقم مؤقت للمستخدم الجديد.	تم التنفيذ
8	البروفايل وكلمة المرور	تحديث البيانات الأساسية، تعيين كلمة المرور، وتغييرها.	تم التنفيذ
9	هدية الترحيب	قراءة قيمة الهدية من إعدادات التطبيق وتسجيل حركة رصيد عند إنشاء الحساب.	تم التنفيذ
10	الباقات والمقالات	الباقات والمزايا، تصنيفات المقالات، قائمة المقالات، وتفاصيل المقال المنشور.	تم التنفيذ
11	الأمان والأخطاء	helmet وCORS وفحص أصل الطلب وZod وrequestId ورد خطأ موحّد.	تم التنفيذ
12	تكامل الواجهة	ربط الواجهة بمسارات الدخول والباقات والمقالات عبر /api/bff/* مع كوكي الجلسة.	تم التنفيذ

أدلة التحقق

- ✓ فحص TypeScript ناجح للويب والـ BFF.
- ✓ /health يرجع database: ok.
- ✓ تسجيل ودخول بكلمة مرور و OTP تم اختبارهم فعليًا.
- ✓ دخول Google وربط الحساب تم اختبارهما فعليًا.
- ✓ الخروج وإلغاء كل الجلسات يعملان.

ملفات التنفيذ الرئيسية

- `bff/src/server.ts` — تأسيس الخدمة وطبقة middleware.
- `bff/src/auth/routes.ts` — مسارات المصادقة.
- `bff/src/auth/session.ts` — الجلسات والكوكيز.
- `bff/src/auth/google.ts` — التحقق من Google.
- `bff/prisma/web_tables.sql` — جداول الويب.

المسارات المنفذة

المصادقة	الباقات والمقالات	الصحة
`POST /api/auth/register/start`	`GET /api/subscriptions/plans`	`GET /health`
`POST /api/auth/register/verify-otp`	`GET /api/blog/categories`	`GET /api/health`
`PATCH /api/auth/register/profile-basics`	`GET /api/blog/articles`	
`POST /api/auth/otp/login/start`	`GET /api/blog/articles/:slugOrId`	
`POST /api/auth/otp/login/verify`		
`POST /api/auth/login`		
`GET /api/auth/google/config`		
`POST /api/auth/google`		
`GET /api/auth/me`		
`POST /api/auth/logout`		
`POST /api/auth/logout-all`		
`POST /api/auth/set-password`		
`POST /api/auth/change-password`		

حدود الإنجاز – مهم للتوضيح

القسم ده يغطي **الباك اند الأساسي** اللي تم تنفيذه. بنود P0 وP1 وP2 في باقي التقرير هي شغل متبقٍ ولم يتم تنفيذه بعد – والفصل بينهم مقصود عشان الصورة تبقى واضحة.

بنود حاجزة للإطلاق

فجوات P0 – أمان وصحة

دي مش تحسينات. دي بنود لو فضلت مفتوحة، الإطلاق يكون غير آمن أو غير صحيح. كل بند هنا ليه أثر مباشر على المستخدم أو على سمعة المنصة.

#	البند	الوضع الحالي	الأثر	المطلوب
1	حماية مسارات الداشبورد	صفحات المستخدم والإدارة مفتوحة لأي زائر بدون جلسة.	أي حد يشوف واجهة المستخدم والإدارة من غير تسجيل دخول.	Guard على السيرفر يتحقق من الجلسة ويحوّل لـ login/.
2	مصادقة وصلاحيات الأدمن	لوحة إدارة كاملة مفتوحة بدون login أو roles.	واجهة إدارية مكشوفة للعامة – خطر أمني وسمعة حتى لو البيانات تجريبية.	تسجيل دخول أدمن منفصل + أدوار + 2FA + Audit Log + فحص صلاحيات.
3	استعادة كلمة المرور	مفيش endpoint ولا شاشة «نسيت كلمة المرور».	أي مستخدم ينسى كلمة المرور يفقد حسابه نهائيًا.	OTP purpose جديد + شاشة + حد أقصى للمحاولات + إبطال الجلسات.
4	إضافة أو تغيير رقم الهاتف	مستخدم Google بياخد رقم وهمي google_<sub>.	مش قادر يستلم OTP ولا يستعيد حسابه ولا يفعّل رقم حقيقي.	Flow لتغيير الرقم مع OTP + فحص عدم التكرار + تحديث الجلسات.
5	سلوك الجلسات	rememberMe بيتبعت وبيتجاهل، ومفيش idle timeout ولا تنظيف دوري.	جلسات أطول من اللازم، تراكم جلسات منتهية، وسلوك غير متوقع.	TTL حسب rememberMe + idle + timeout + إبطال عند تغيير كلمة المرور + cleanup job.
6	Rate limiting و lockout	الحد في الذاكرة فقط، ومحاولات الدخول بتتسجل بدون قفل للحساب.	Brute force و OTP abuse، والحد بيضيع مع restart أو تعدد السيرفرات.	Store مشترك (Redis) + قفل مؤقت للحساب + تنبيهات.
7	حفظ الـ Onboarding	الخطوة 7 بتنادي done() بدون إرسال أي بيانات لـ BFF.	المستخدم يوصل لداشبورد وملفه فاضي – تجربة مكسورة من أول خطوة.	حفظ البروفايل + تحقق من الاكتمال + منع الدخول للداشبورد قبل الحفظ.
8	تقوية إعدادات الإنتاج	الإعدادات الحساسة يدوية وغير مفروضة، ومفيش CSP مضبوط للويب أو مراجعة أصول.	احتمال نشر بكوكيز غير آمنة أو CORS غير مضبوط أو أخطاء إعداد.	فحص env عند الإقلاع + كوكيز آمنة + CORS + CSP على الدومين النهائي + HTTPS.

أخطر بندين في القائمة

لوحة الإدارة المكشوفة أولًا: أي زائر يقدر يفتحها، وحتى لو البيانات تجريبية دلوقتي، الشكل نفسه غير مقبول في الإنتاج. **وحفظ الـ onboarding** ثانيًا: من غير حفظ، كل مستخدم جديد هيوصل لداشبورد فاضي وده هيكسر الثقة من أول استخدام.

ملاحظة مهمة عن الحماية

حماية الواجهة بالكود في المتصفح مش كفاية. لازم التحقق يحصل على السيرفر (middleware أو server component) قبل تحميل أي شاشة، وأي API حساس يتحقق من الجلسة والصلاحية بنفسه – مش يعتمد على إن الواجهة مخبية الزرار.

استكمال المنتج نفسه

06

فجوات P1 – ربط الأقسام بالبيانات

بعد ما نقفل P0، يبدأ الشغل الحقيقي: كل قسم في الداشبورد حاليًا واجهة محلية ببيانات ثابتة. المطلوب API وحفظ حقيقي وقواعد واضحة لكل قسم.

المجال	الوضع الحالي	المطلوب	الأولوية
الـ Onboarding والملف الشخصي	بيانات محلية في المتصفح، مفيش حفظ.	GET/PATCH للبروفايل + رفع صور + تحقق من الاكتمال.	P1
الترشيحات والبحث	كروت وفلاتر محلية.	/Recommendations + Search APIs + pagination + like skip.	P1
الاهتمامات	قائمة محلية.	CRUD للاهتمامات + حدود حسب الباقة.	P1
الرسائل	محادثات وهمية.	Conversations + Messages + Receipts + Block/Report.	P1
الإشعارات	مفاتيح تشغيل محلية.	Notifications API + read state + push/email.	P1
المحفظة والاشتراكات والدفع	رصيد وهمي وزرار باقة بيودّي للـ onboarding.	Wallet + ledger + packages + Paymob/Fawry + webhooks + فواتير + استرداد.	P1
الخصوصية والإعدادات	مفاتيح محلية بدون حفظ.	Privacy prefs + notification prefs + sessions/devices + حذف/تصدير الحساب.	P1
الولي والأسرة	دعوات وصلاحيات وهمية.	دعوات حقيقية + صلاحيات + موافقات + سجل.	P2
المجتمع	بوستات وتعليقات وهمية.	Posts + Comments + Reactions + Reporting + Moderation.	P2
المكالمات	واجهة فقط بدون مزود.	مزود مكالمات + جدولة + موافقة الطرفين + تسجيل/إبلاغ.	P2
إزالة البيانات التجريبية	PrototypeNotice ظاهر في الأقسام.	حذف كل mock data وربط كل شاشة بمصدرها الحقيقي.	P1

توصية لإطلاق MVP أسرع

لو الهدف هو إطلاق تجاري أسرع، نرشح تأجيل **المجتمع والمكالمات والولي** في أول نسخة، والتركيز على: الـ onboarding، الملف الشخصي، الترشيحات، الاهتمامات، الرسائل، الإشعارات، والمحفظة/الدفع. كده التجربة الأساسية تكون كاملة من غير ما نفتح كل الأقسام مرة واحدة.

قبل ربط أي قسم

لازم نتفق على شكل البيانات وقواعد العمل لكل قسم: مين يقدر يشوف مين، إيه حدود الباقة المجانية، إيه اللي بيتسجل في الـ audit، وإيه اللي بيتحذف لما الحساب يتقفل. الاتفاق ده قبل الكود بيوفر إعادة شغل كبيرة.

التشغيل والبنية التحتية

فجوات P2 – جاهزية التشغيل

دي مش أقل أهمية، لكنها مش بتوقف تجربة المستخدم يوم الإطلاق. لو اتأجلت، لازم يكون فيه خطة واضحة قبل النمو – لأن أي مشكلة في التشغيل بعد الإطلاق بتتحول بسرعة لمشكلة ثقة.

البند	الوضع الحالي	المطلوب
إدارة قاعدة البيانات	جداول الويب بتتعمل يدويًا من web_tables.sql.	Prisma baseline + migrate deploy + بيئة staging + خطة rollback.
الاختبارات	مفيش اختبارات آلية للويب أو الـ BFF.	Unit + Integration + E2E للمسارات الحرجة (دخول، دفع، رسائل).
CI/CD	مفيش pipeline.	Lint + Typecheck + Test + Build + Deploy تلقائي مع حماية الفروع.
النشر	مفيش Dockerfile ولا reverse proxy ولا HTTPS موثّق.	Docker/ + Nginx/Caddy + TLS + graceful shutdown + health readiness.
المراقبة	مفيش لوجز منظمة أو تتبع أخطاء أو تنبيهات.	Structured logs + Sentry + metrics + uptime alerts + request tracing.
النسخ الاحتياطي	غير موثّق.	نسخ يومي + PITR + اختبار استرجاع دوري.
SEO	metadata أساسية و robots فقط.	Metadata لكل صفحة + canonical + Open Graph + sitemap + hreflang.
المحتوى القانوني	مفيش صفحات شروط أو خصوصية أو استرداد.	صفحات قانونية معتمدة + Cookie consent + سياسة احتفاظ بالبيانات.
الأداء وإتاحة الوصول	لم يتم قياسه بشكل منهجي.	Core Web Vitals + Lighthouse + فحص WCAG الأساسي.
البريد المعاملاتي	مفيش مزود بريد.	إرسال إشعارات وفواتير وإعادة تعيين – مع قوالب ومراقبة التسليم.

أهم بندين في P2

النسخ الاحتياطي و**المراقبة**. أي منصة زواج فيها بيانات حساسة؛ لو حصل عطل ومفيش نسخة احتياطية قابلة للاسترجاع، الخسارة مش تقنية بس. والمراقبة هي اللي هتعرفنا إن فيه مشكلة قبل ما المستخدمين يشتكوا.

تفصيل شاشة بشاشة

08

أقسام الداشبورد: الحالة والمطلوب

الـ 12 قسم دول هم قلب المنتج. كلهم حاليًا ببيانات محلية أو ثابتة، ومحتاجين API وحفظ وقواعد عمل. الجدول ده هو خريطة الشغل لكل قسم.

القسم	الوضع الحالي	المطلوب قبل الإطلاق	الأولوية
الرئيسية	إحصائيات وكروت وهمية.	ملخص حقيقي: ترشيحات، رسائل، إشعارات، ونشاط الحساب.	P1
الترشيحات	كروت ثابتة بدون تفاعل حقيقي.	Recommendations API + فلاتر + Like/Skip + سبب الترشيح.	P1
البحث المتقدم	فلاتر محلية بدون نتائج حقيقية.	Search API + pagination + حفظ البحث + احترام الخصوصية.	P1
الاهتمامات	قائمة محلية.	CRUD + حدود الباقة + ربطها بالترشيحات.	P1
المحفظة	رصيد 1250 وسجل حركة وهمي.	Wallet + Credit ledger + Packages + Payment + فواتير.	P1
الولي والأسرة	دعوات وصلاحيات وهمية.	دعوة حقيقية + قبول/رفض + صلاحيات + موافقات + سجل.	P2
المجتمع	بوستات وتعليقات وهمية.	Posts + Comments + Reactions + Report + Moderation.	P2
المكالمات	واجهة بدون مزود أو جدولة.	مزود مكالمات + مواعيد + موافقة + إبلاغ + تسجيل حسب السياسة.	P2
الرسائل	محادثات وهمية.	Conversations + Messages + Receipts + Block/Report + حدود الباقة.	P1
الإشعارات	مفاتيح تشغيل محلية.	Notifications API + read/unread + push/email + تفضيلات.	P1
الملف الشخصي	بيانات محلية بدون حفظ.	GET/PATCH + صور + مراجعة + جودة الملف + التحقق.	P1
الخصوصية والإعدادات	مفاتيح محلية بدون حفظ.	Privacy prefs + sessions/devices + حذف الحساب + تصدير البيانات.	P1

ملاحظة عن «الرئيسية»

الصفحة الرئيسية للداشبورد مش قسم مستقل؛ هي ملخص لكل الأقسام التانية. عشان كده مش هتشتغل صح قبل ما الأقسام الأساسية (الترشيحات، الرسائل، الإشعارات) تتوصل ببيانات حقيقية.

الترتيب والمدد

خطة التنفيذ المقترحة

الخطة مقسمة على مراحل عشان كل مرحلة تنتج حاجة قابلة للاختبار. المدد تقديرية وتفترض فريق 2–3 مطورين، وقرارات العميل جاهزة في بداية كل مرحلة.

المرحلة	المحتوى	المدة	المخرج
المرحلة 0	بنود P0: حماية المسارات، الأدمن، استعادة كلمة المرور، تغيير الرقم، الجلسات، rate limiting، حفظ الـ onboarding، تقوية الإنتاج.	2–3 أسابيع	نسخة آمنة قابلة للاختبار الداخلي.
المرحلة 1	الملف الشخصي والخصوصية والإعدادات + رفع الصور + جلسات الأجهزة.	2–3 أسابيع	ملف حقيقي وإعدادات محفوظة.
المرحلة 2	الترشيحات والبحث والاهتمامات والرسائل والإشعارات.	3–5 أسابيع	تجربة اكتشاف وتواصل كاملة.
المرحلة 3	المحفظة والاشتراكات والدفع + webhooks + فواتير + استرداد.	2–4 أسابيع	تحصيل فعلي وإدارة اشتراك.
المرحلة 4	لوحة الأدمن الحقيقية + المجتمع + الولي + المكالمات حسب الأولوية.	3–5 أسابيع	إدارة تشغيلية ومزايا إضافية.
المرحلة 5	الاختبارات و CI/CD والمراقبة والنسخ الاحتياطي والمحتوى القانوني و SEO واختبار الحمل.	2–3 أسابيع	إطلاق production مستقر.

افتراضات مهمة

- إعادة استخدام APIs الموبايل المتاحة يقلل المدة بشكل كبير.
- أي تأخير في قرار الدفع أو النصوص القانونية بيأثر على الجدول.
- المدد لا تشمل إعادة تصميم الواجهة أو مزايا جديدة.

الإجمالي التقديري

14–23 أسبوعًا للنطاق الكامل حسب سرعة القرارات وحجم إعادة استخدام APIs الموبايل. لو المطلوب MVP فقط، يمكن ضغط الخطة إلى **8–12 أسبوعًا** بتأجيل المجتمع والمكالمات والولي.

الترتيب مش قابل للعكس

ما ينفعش نبدأ بالدفع أو المجتمع قبل حماية المسارات وحفظ الـ onboarding. كل مرحلة بتعتمد على اللي قبلها، والبدء في المزايا قبل الأساس بيضاعف إعادة الشغل.

إمتى نقول إننا خلصنا؟

معايير القبول قبل الإطلاق

عشان الإطلاق ما يبقاش رأيًا شخصيًا، دي معايير واضحة نقيس بيها الجاهزية. أي بند منها لو مش متحقق، النسخة تعتبر غير جاهزة للنشر العام.

المجال	معيار القبول
حماية الوصول	مفيش صفحة داشبورد تفتح بدون جلسة صالحة، ولوحة الإدارة تتطلب دورًا مصرحًا به.
الأدمن	تسجيل دخول أدمن منفصل + أدوار + Audit Log لكل عملية حساسة.
استعادة الحساب	مستخدم يقدر يعمل reset بكلمة مرور جديدة عبر OTP، وكل الجلسات القديمة تتلغي.
رقم الهاتف	مستخدم Google يقدر يضيف رقمًا حقيقيًا ويتحقق منه ويستخدمه في OTP.
الجلسات	rememberMe بيغيّر مدة الجلسة فعليًا، والجلسات المنتهية بتتنظف دوريًا.
مكافحة الإساءة	Rate limit شغال عبر السيرفرات، وقفل مؤقت بعد محاولات فاشلة متكررة.
الـ Onboarding	كل خطوة بتتحفظ، ومفيش وصول للداشبورد قبل اكتمال البيانات الأساسية.
البيانات الحقيقية	صفر mock data وصفر PrototypeNotice في نسخة الإنتاج.
الدفع	دورة كاملة في sandbox: اشتراك ← webhook ← تفعيل ← فاتورة ← استرداد.
الجودة	Typecheck + Build + اختبارات E2E للمسارات الحرجة بتمر في CI مع كل Pull Request.
التشغيل	HTTPS + مراقبة + تنبيهات + نسخة احتياطية تم اختبار استرجاعها.
القانوني	الشروط والخصوصية والاسترداد منشورة، والموافقة بتتسجل.

تعريف «جاهز للإطلاق»

جاهز للإطلاق يعني: مستخدم جديد يقدر يسجل، يكمل ملفه، يشوف ترشيحات، يتواصل بأمان، يدفع، ويستعيد حسابه — كل ده على بيانات حقيقية، مع مراقبة ونسخ احتياطي، ومن غير أي واجهة تجريبية ظاهرة.

لو أطلقنا بالوضع الحالي

مخاطر الإطلاق الآن

المخاطر دي مش افتراضية. كل واحدة ليها سبب واضح في الكود الحالي، وكلها قابلة للمعالجة لو اتنفذت بنود P0 وP1 بالترتيب.

الخطر	الاحتمال	الأثر	التخفيف
وصول عام للوحة الإدارة	مؤكد	عالي	حماية المسارات + مصادقة أدمن + صلاحيات.
ظهور بيانات وهمية للمستخدمين	مؤكد	عالي	ربط الأقسام أو إخفاؤها قبل الإطلاق.
عدم قدرة المستخدم على استعادة حسابه	مرتفع	عالي	استعادة كلمة المرور + تغيير رقم الهاتف.
إساءة استخدام OTP أو تسجيل الدخول	متوسط	عالي	Rate limit مشترك + lockout + تنبيهات.
عدم وجود تحصيل أو اشتراكات	مؤكد	عالي	بوابة دفع + webhooks + فواتير.
فقدان بيانات أو عطل غير مرصود	متوسط	عالي	نسخ احتياطي + PITR + مراقبة وتنبيهات.
مشاكل قانونية أو خصوصية	متوسط	عالي	صفحات قانونية + موافقات + سياسة احتفاظ وحذف.

تكلفة التأجيل مقابل تكلفة الإطلاق

تأجيل الإطلاق أسبوعين لإغلاق P0 أرخص بكثير من إطلاق منصة بمخاطر أمنية أو تجربة مكسورة. أول انطباع عن المنصة بيتشكل في أول دقائق من استخدام المستخدم، وصعب يتصلح بعد كده.

عشان نبدأ صح

قرارات مطلوبة من العميل

فيه قرارات مش تقنية بالكامل، وأي تأخير فيها بيأخر المرحلة اللي بعدها. القرارات دي محتاجة تتحدد قبل بدء التنفيذ، مش أثناءه.

بوابة الدفع

Paymob أو Fawry أو غيرهم، وبيانات التاجر، وبيئة الاختبار، وسياسة الاسترداد.

نطاق الإطلاق

هل الهدف MVP سريع ولا النطاق الكامل؟ وإيه الأقسام اللي لازم تكون live يوم الإطلاق؟

الإشعارات والبريد

قنوات الإشعار المطلوبة، ومزود البريد المعاملاتي، وقوالب الرسائل.

مزود المكالمات

هل المكالمات ضمن الإطلاق الأول؟ ولو نعم، Agora أو Twilio أو مزود محلي؟

النصوص القانونية

الشروط والخصوصية والاسترداد، وسياسة الاحتفاظ بالبيانات وحذف الحساب.

صلاحيات الأدمن

مين هيدخل لوحة الإدارة، وإيه الأدوار، ومين يعتمد المحتوى أو الاسترداد؟

إعادة استخدام APIs

هل نستخدم APIs الموبايل الموجودة ولا نبني مسارات ويب مخصصة؟ ده بيحدد الجدول والتكلفة.

الاستضافة والدومين

الدومين النهائي، السيرفر، شهادة HTTPS، وخطة النسخ الاحتياطي والاسترجاع.

قرار واحد بيوقف كل حاجة

لو مفيش بوابة دفع متفق عليها، مرحلة الاشتراكات كلها هتتأجل. ولو مفيش نصوص قانونية معتمدة، الإطلاق العام هيتأجل حتى لو الكود جاهز. الأفضل نحسم القرارات دي بالتوازي مع تنفيذ P0.

الخلاصة والخطوة الجاية

13

نبني على أساس سليم، مش نطلق بسرعة

الأساس التقني للويب سليم: واجهة حديثة، BFF مستقل، جلسات آمنة، ومصادقة حقيقية. اللي ناقص هو استكمال المنتج وتقفيل مخاطر الإطلاق. لو اتعمل ده بالترتيب، المنصة تقدر تنطلق بثقة وتنمو من غير إعادة بناء.

1. اعتماد النطاق

اختيار MVP أو النطاق الكامل، وتحديد الأقسام المطلوبة يوم الإطلاق.

2. تقفيل P0

حماية المسارات، الأدمن، استعادة الحساب، الجلسات، وحفظ الـ onboarding.

3. اختبار ثم إطلاق

اختبار داخلي شامل، قرار Go/ No-Go، ثم إطلاق تدريجي مع مراقبة.

التوصية النهائية

الأساس جاهز – والمنتج محتاج مرحلة استكمال

نبدأ فورًا في بنود P0، وبعدها نبني التجربة الأساسية (ملف، ترشيحات، تواصل، دفع) على مراحل قصيرة قابلة للاختبار. كده كل أسبوع بيقرّبنا من إطلاق حقيقي، مش مجرد واجهة شكلها جاهز.

التاريخ

9 نوفمبر 2026

إعداد وتنفيذ

محمد مضيان – مراجعة جاهزية الويب